Security Incident Brief: Internal Administrator Impersonation

Threat Actor TTP: Credential Harvesting & Unauthorized MFA Interception

Incident Narrative

An adversary masquerading as Senior Enterprise Identity Administrator 'Alex Turner' sent direct urgent prompts instructing engineering personnel to enter their root Active Directory credentials and submit authenticator one-time passwords.

Captured Attack Communication

FROM: Global IT Identity Support TO: devops-core@enterprise.example.org SUBJECT: CRITICAL: Mandatory Okta MFA Re-Enrollment Protocol

Message Transcript

URGENT ATTENTION REQUIRED: Due to an active database patch failure, your corporate identity profile has become desynchronized. You are required to submit your current domain password, username, and temporary MFA token immediately to prevent system lockout. Navigate to the identity synchronization gateway: hxxp://sso-auth-reset[.]example[.]org/login.php?session=938210 Enter your enterprise username, password, and approve the Duo push request that appears on your mobile device. Do not contact the helpdesk as phone lines are undergoing emergency maintenance. Technical Support Operations | IP Gateway: 203.0.113.88

Technical IOCs & Threat Analysis

This communication matches explicit credential theft behavioral rules, including asking for passwords, authenticator tokens, and instructing victims not to verify the request through secondary channels.

IOC Value	Type	Confidence	Classification
sso-auth-reset[.]example[.]org	Domain	0.99	Phishing Landing Page
203.0.113.88	IPv4	0.95	Adversary Infrastructure
it-identity-support@sso-internal-portal[.]example[.]org	Email	0.98	Spoofed Identity
hxxp://sso-auth-reset[.]example[.]org/login.php	URL	0.99	Credential Collector

Correlated ATT&CK; Framework Techniques

• **T1056.003 (Input Capture: Web Portal Capture)**: Harvesting credentials via spoofed login.

• **T1110 (Brute Force / Password Spraying)**: Subsequent phase targeting related systems.

• **T1621 (Multi-Factor Authentication Request Generation)**: MFA push bombing attack vector.

Incident Response Playbook

Recommended containment sequence for Active Directory credential compromises:

• Invalidate all Kerberos Ticket Granting Tickets (TGT) for affected user accounts.

• Reset FIDO2 and authenticator token bindings.

• Inspect Azure AD / Okta sign-in logs for connections originating from `203.0.113.88`.

• Terminate active VPN tunnels associated with targeted engineer profiles.

Severity Assessment: CRITICAL (9.4 / 10.0)